Projet de recherche - Agent Intelligent pour l'Analyse et la Validation de la Confidentialité des Architectures Système

Wejden Abdallah, Michel Bourdellès

ESIEE-IT

September 1, 2026

Abstract

Le thème de ce projet est de définir des agents IA. Ces agents de conversation avec les ingénieurs en charge de la réalisation de systèmes sont utilisés pour modifier la spécification de systèmes. Ces modifications permettent de proposer des choix de conception répondant au mieux au besoin.

1 Contexte du projet de recherche

La réalisation de systèmes industriels nécessite dans un premier temps d'en capturer la spécification, souvent exprimée comme une somme d'exigences. Ces exigences sont ensuite traduites comme modèle dans des outils industriels de modélisation pour l'ingénierie systèmes tels que SysML ou Capella/Arcadia. Le raffinement de ces modèles permet de faire des choix de conception système pour leur réalisation logicielle et matérielle.

La description des composants, interfaces et flux de traitements portée par les outils de modèlisation sont bien documentés et non ambigus. Des transformations de modèles à partir de ces descriptions permettent de produire des représentations formelles RF à base d'automates simples. Des algorithmes s'appliquant sur ces représentations et en déduisent si les choix de conception satisfont les exigences initiales. Le travail proposé s'intègre dans ce pipeline de production de code permettant la validation automatique des exigences d'entrée du système.

Cette approche contient cependant un certain nombre de limitations. La première de ces limitations est que le travail de rafinement de la modélisation de spécification à un choix de conception, réalisé par des choix de spécialistes systèmes. Ce raffinement n'étudie souvent qu'un ensemble limité des combinaisons possibles permettant de satisfaire le besoin d'entrée. Une limitation est

aussi que la conception, suite à son analyse, ne valide pas les exigences d'entrée. D'autre part, l'espression du besoin peut changer en cours de projet, et cela amène à refaire tout le travail de conception système et validation.

Le modèle formel de représentation du système RF étant bien défini, ainsi que les règles permettant de vérifier que que celui-ci répond aux exigences d'entrée, nous proposons de les injecter dans une base d'un agent IA afin que celui-ci puisse analyser les solutions possibles et production de directives et code spécifique. Les spécialistes systèmes pourront adapter les exigences d'entrée et les contraintes d'infrastructures par des requêtes à l'agent IA.

Dans cette étude nous nous concentrons sur un modèle de référence permettant l'analyse de sécurité $RFsec$. Le travail demandé consiste à exploiter la formalisation des $RFsec$ étendus pour spécialiser un choix de conception en utilisant des agents IA correspondant à la tenue des exigences de sécurité de systèmes instances de ces SFC. ce choix étant au final validé par des méthodes algorithmiques plus classiques. Une attention particulière est portée sur la capacité à partager les informations sur des agents IA globaux et locaux garantissant la protection en confidentialité des informations sensibles des systèmes à concevoir.

2 Formalisation des $RFsec$

Un travail est de décrire formellement le modèle permettant une analyse en confidentialité, à injecter à l'agent IA.

Schématiquement, comme présenté en Figure 1, la modélisation de système capture dans la vue physique les informations du système décrits comme des déploiements de flux de données sur des modèles de plateforme. Nous partons de cette représentation pour l'enrichir d'informations nécessaires pour réaliser une analyse de sécurité.

Function : L'enrichissement proposé ajoute une caratérisation de l'impact des fonctions des flux de données sur la données y transitant. Ces fonctions peuvent, soit créer la données du flux, soit la lire, soit la transmettre sans nécessité d'avoir accès à la donnée, soit modifier la donnée. En cas de création, ou modification de la donnée, un niveau de confidentialité est affecté à la donnée produite.

Flux de données : Un flux de données décrit une séquence de fonctions, initiée par une fonction auquelle est associée un niveau de confidentialité. Si une échéance D est définie pour une séquence de traitements d'une chaîne fonctionnelle, celle-ci est associée au flux de données identifé.

Platform : Ces flux de donnés sont déployés sur des modèles de plateformes capturés comme des séquences d'enclaves sur lesquels sont déployés les noeuds traitements des flux. La protection en sécurité de ces flux s'appuie sur des services plateformes permettant la mise en oeuvre de mécanismes dont nous enrichissons le modèle. Ainsi est annotée l'information de protection contre un accès par un agent malveillant, relative au niveau de sensibilité de la donnée dans l'enclave. La protection en confidentialité ou intégrité peut nécessiter

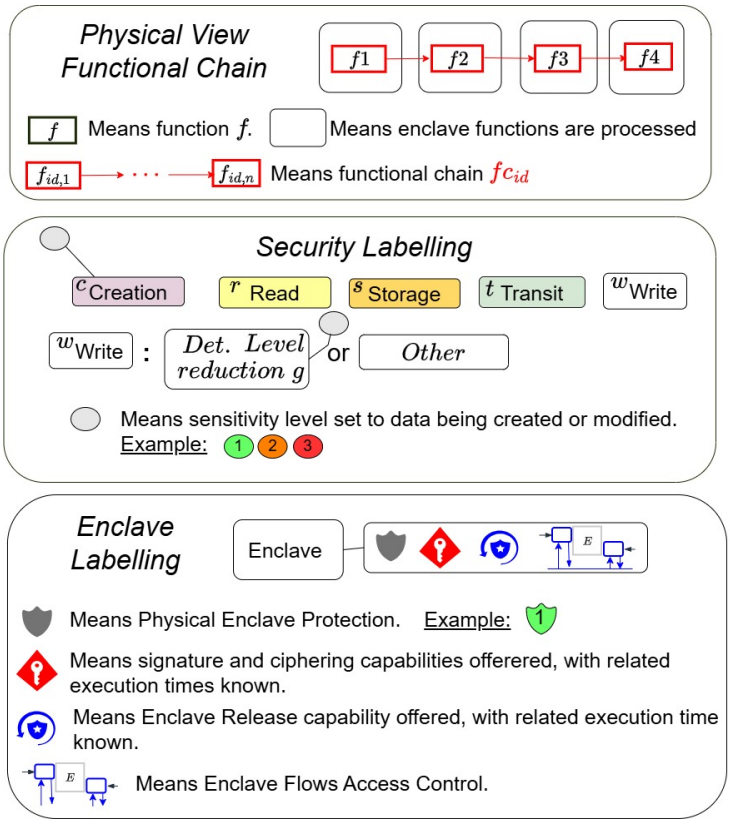


Figure 1: Représentation graphique du modèle $RFsec$

l'utilisation de traitements cryptographiques (chiffrements, signatures). Aux enclaves est aussi associé la disponibilité d'accès sûr de ces traitements relatives à un niveau de sensibilité des données. Plusieurs flux de données peuvent transiter dans la même enclave, partageant les mêmes unités de calcul et de localité mémoire. Ces partages de mêmes ressources physiques peuvent amnener à des contaminations d'informations inter flux avec des risques de divulgation d'informations confidentielles.

La politique d'affectation de niveau de sensibilité des données sortant d'une enclave est par défaut la somme des niveaux de sensibilités des données de tous les flux accédant à l'enclave. Certaines de ces enclaves peuvent offrir un service de contrôle d'accès des flux de données, contrôlé par des informations issues de l'analyse de la conception du système. Certaines de ces enclaves peuvent en complément offrir un service de réinitialisation de contexte de l'enclave, considéré comme suffisant pour éviter les contaminations inter-flux.

Enfin, les traitements sont réalisées sur des composants d'une plateforme physique qui peuvent offrir un certain nombre de services:

- Une protection en compromission du composant, relative à univeau de sensibilité d'information à protéger.
- Un servide de traitements cryptographiques tels que la génération et stockage de clefs, calculs de hashs et chiffrements.
- Une capacité de reset de contexte du composant considéré suffisant pour ne pas accéder à des informations mémorizées avant le reset.
- Un service de gestion à l'accès à l'enclave des données de flux différents.

3 Protections des données en confidentialité

Cette protection se fait par protection des enclaves contre la compromission, par suppression de la confidentialité des informations comme résultat d'un traitement et enfin par protection par chiffrement. La protection en enclave est modélisée en phase de conception système en associant à une enclave un niveau de protection relatif au niveau de sensibilité des données transitant dans l'enclave. Il s'agira dans la réalisation de ce système de garantir tant en contrôle d'accès qu'en protection contre des accès malveillants que les mesures soient mises en oeuvre pour garantir ce niveau attendu de protection logicielle et physique. Ces trois cas sont présentés en Figure 3. Comme l'accès en lecture ou en écriture nécessite d'avoir accès à la donnée en clair, la protection en chiffrement ne peut pas convenir dans ce cas.

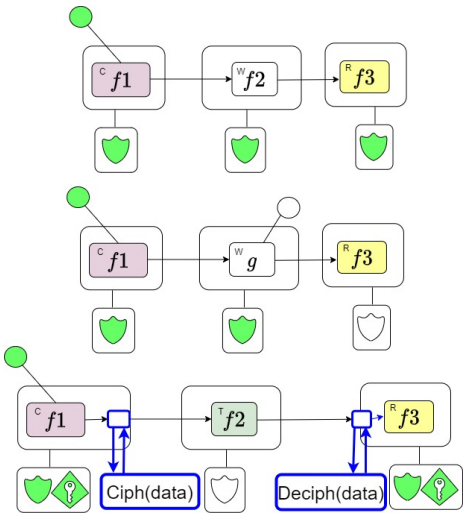


Figure 2: Three Confidentiality Data Protections

Un besoin de protection des contaminations inter-flux est nécessaire lorsque deux flux de données partagent une même enclave, une même localité de traite-

ments de calculs et de mémoires. Cette localité peut amener à de la divulgation d'information. Cette problématique est connue avec plusieurs propositions d'atténuation de cette problématique. Les solutionss présentées soit répondent à un contexte applicatif un peu différent, soit présentent une solution partielle à la prise en compte dans la représentation enrichie de flux de données déployés sur des modèles d'enclaves.

Nous présentons en complément de la situation de contamination de niveaux de sensibilité en Figure 3.1, trois situations d'atténuation de ce risque de contamination en Figure 2. Le premier par chiffrement.... le second par protection en intégrité... Le troisième par contrôle à l'accès à l'enclave avec réinitialisation du contexte d'exécution après le traitement d'un flux sensible....

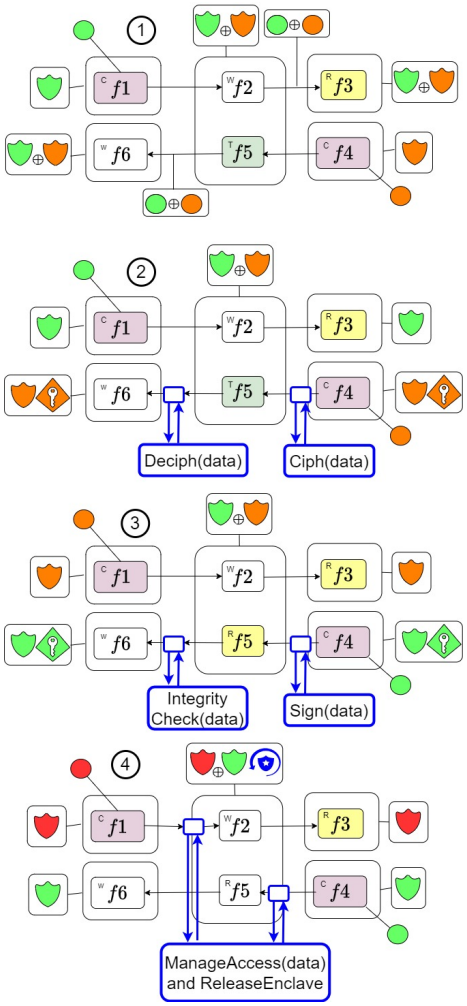


Figure 3: Confidentiality Contamination and Mitigation Cases

4 Processus d'analyse de confidentialité

L'analyse se fait en appliquant les règles d'inférence de la Figure 5 afin de garantir que la plateforme offre les éléments de sécurité en protection d'enclaves à la compromission ainsi que la mise à disposition de services plateformes de sécurité suffisants pour garantir les besoins initiaux de sécurité.

Cette analyse se complète de l'identification des besoins d'exploitation de ces services plateforme à mettre en oeuvre.

5 Elements de solution de mise en oeuvre

Développer un agent conversationnel basé sur un LLM et augmenté par RAG, capable d'assister un ingénieur système dans l'analyse de confidentialité d'une architecture. L'agent devra :

1. recueillir et clarifier les exigences de sécurité
2. exprimées en langage naturel ;
3. transformer ces exigences en une représentation
4. structurée compatible avec RFsec ;
5. détecter les protections de sécurité manquantes ;
6. proposer une ou plusieurs modifications de conception ;
7. appeler un moteur formel pour vérifier ces propositions ;
8. expliquer à l'ingénieur les résultats, les hypothèses et les protections à mettre en œuvre ;
9. conserver la traçabilité entre exigences, éléments RFsec, règles appliquées et décisions proposées.

Cette définition prolonge directement le pipeline décrit précédemment : exigences, modèle système, représentation formelle, choix de conception et validation algorithmique. L'agent doit analyser plusieurs solutions, produire des directives ou du code spécifique, tandis que la solution finale reste validée par des méthodes algorithmiques classiques.

L'objectif de ce projet est de concevoir un assistant intelligent capable d'accompagner un ingénieur système lors de la conception et de l'analyse d'architectures sécurisées. Contrairement à un simple chatbot, l'agent développé devra être capable de comprendre un problème de sécurité exprimé en langage naturel, de l'analyser, de proposer des solutions techniques pertinentes et de vérifier automatiquement leur validité à l'aide de méthodes formelles.

L'idée générale repose sur une collaboration entre l'intelligence artificielle et les méthodes classiques de cybersécurité. L'IA apporte des capacités de

compréhension, d'analyse et de génération de solutions, tandis que les moteurs formels garantissent la validité des résultats. L'agent n'a donc pas pour objectif de remplacer l'ingénieur système, mais de lui servir d'assistant intelligent capable d'accélérer les phases d'analyse et de conception tout en conservant un niveau élevé de fiabilité.

Pour atteindre cet objectif, la solution s'appuie sur un modèle de langage (LLM) enrichi par une approche RAG (Retrieval-Augmented Generation). Cette technique permet à l'agent de consulter une base documentaire spécialisée avant de répondre. Ainsi, les recommandations produites ne reposent pas uniquement sur les connaissances générales du modèle, mais également sur des sources de référence telles que les guides de l'ANSSI, les normes ISO 27001, les recommandations du NIST, les contrôles CIS ou encore la documentation associée à RFsec. L'agent est ainsi capable de fournir des réponses cohérentes avec les bonnes pratiques de cybersécurité et les exigences réglementaires.

La première étape du traitement consiste à recueillir et clarifier les besoins exprimés par l'ingénieur système. Dans de nombreux cas, les exigences de sécurité sont formulées de manière incomplète ou ambiguë. L'agent doit alors jouer le rôle d'un expert capable de dialoguer avec l'utilisateur afin d'obtenir toutes les informations nécessaires. Il peut par exemple demander des précisions sur la nature des données manipulées, les différents types d'utilisateurs, les contraintes réglementaires applicables ou encore les niveaux de confidentialité attendus. Cette phase de dialogue permet progressivement de construire une vision complète du système étudié.

Une fois les exigences correctement identifiées, l'agent procède à leur transformation vers une représentation structurée exploitable par RFsec. Cette étape constitue un élément clé du projet puisqu'elle assure la transition entre le langage naturel et les modèles formels. Les informations collectées sont converties sous forme d'actifs, d'acteurs, de flux, de propriétés de sécurité et de contraintes de confidentialité. Cette représentation formelle permet ensuite d'automatiser les analyses de sécurité.

À partir de ce modèle, l'agent réalise une évaluation de l'architecture afin d'identifier d'éventuelles faiblesses. Il recherche notamment l'absence de mécanismes de protection indispensables tels que le chiffrement des communications, les contrôles d'accès, la séparation des privilèges ou encore les mécanismes de traçabilité. L'objectif est de détecter les protections manquantes avant qu'elles ne deviennent des vulnérabilités exploitables dans un contexte réel.

Lorsque des problèmes sont identifiés, l'agent propose plusieurs solutions d'amélioration. Plutôt que de fournir une réponse unique, il est capable de générer différentes alternatives de conception présentant chacune des avantages et des contraintes spécifiques. Certaines propositions pourront privilégier la simplicité de déploiement tandis que d'autres mettront l'accent sur un niveau de sécurité plus élevé. L'ingénieur dispose ainsi de plusieurs scénarios qu'il pourra comparer en fonction des contraintes du projet.

Une caractéristique essentielle de la solution réside dans la vérification systématique des architectures proposées. Chaque modification générée par l'agent est transmise à un moteur formel chargé de vérifier automatiquement que les propriétés

de sécurité attendues sont effectivement satisfaites. Cette étape permet de garantir que les recommandations produites par l'IA sont cohérentes avec les exigences exprimées initialement. Si une solution ne respecte pas les contraintes définies, elle est rejetée ou corrigée avant d'être présentée à l'utilisateur.

Après la phase de vérification, un module d'explication intervient afin de rendre les résultats compréhensibles par l'ingénieur système. L'agent ne se limite pas à indiquer qu'une architecture est valide ou invalide ; il explique les raisons de son analyse, les hypothèses prises en compte, les menaces identifiées ainsi que les bénéfices des protections proposées. Cette capacité d'explication est particulièrement importante dans un contexte pédagogique car elle permet aux étudiants de comprendre le raisonnement suivi par le système.

Enfin, l'ensemble du processus doit assurer une traçabilité complète des décisions prises. Chaque exigence exprimée par l'utilisateur doit pouvoir être reliée aux éléments RFsec correspondants, aux règles de sécurité utilisées, aux modifications proposées par l'agent ainsi qu'aux résultats obtenus lors de la vérification formelle. Cette traçabilité facilite l'audit du système et permet à l'ingénieur de justifier chacune des décisions de conception retenues.

D'un point de vue technique, la plateforme pourra être développée en Python à l'aide d'un framework tel que FastAPI. Le modèle de langage pourra être orchestré au moyen de LangChain ou LangGraph, tandis qu'une base vectorielle comme Qdrant ou Weaviate assurera le stockage des connaissances exploitées par le mécanisme RAG. Les moteurs de vérification formelle tels que RFsec, Alloy, ProVerif ou Tamarin viendront compléter la chaîne d'analyse afin de garantir la robustesse des résultats.

À la fin du projet, les étudiants devront démontrer qu'il est possible de partir d'une description textuelle d'une architecture, de construire automatiquement un modèle de sécurité, d'identifier les problèmes de confidentialité, de proposer plusieurs améliorations, de vérifier leur validité et d'expliquer de manière claire les résultats obtenus. Le projet illustre ainsi la complémentarité entre les techniques modernes d'intelligence artificielle et les méthodes formelles de cybersécurité, deux domaines devenus incontournables dans la conception des systèmes numériques de demain.

References